

Partial Exam 24/10/2022

includes solutions.

1 Part 1, Mandatory

Honor Code
I have read and understood the rules (summary: only course resources, no communication with others) and follow them.

☐ Yes

☐ No

T/F statements [for E]
Assignment: For each of the statements, classify them as true or false and explain your reasoning.

1. A burglar alarm is the real-world equivalent of an intrusion detection system.

Solution: True. It has sensors placed around the area it protects. If any sensor reports under certain conditions, it will report an intrusion attempt. Just as an intrusion detection system would. *[Correct reasoning explains similarity.]*

2. A packet filtering firewall filters out specific content from network packets.

Solution: False. 1) A packet filtering firewall simply drops entire packets based on metadata. 2) It never looks at content. *[Correct reasoning makes at least one of these points.]*

3. Some DOS attacks can be countered by designing the system to use multiple service providers for the same functionality.

Solution: True. For example, we could set up a system to use two DNS servers. If the first one is not available (e.g., because itself is a victim of a DOS) then we can switch to the second indepent service. *[Correct reasoning points out that the first one can fail.]*

4. Privacy is a synonym for confidentiality.

Solution: False. Privacy is a more complex notion than just preventing unauthorized read access, e.g. privacy is also about metadata, control over data, human rights, context, etc. *[Correct reasoning points out that privacy is more than confidentialiy.]*

5. Allowing students write access to all canvas pages in a course goes against the principle of economy of mechanism.

Solution: False, 1) it goes against the principle of least privilege as they only need read access to most pages unless a task requires them to write. 2) Economy of mechanism means that a security mechanism should not be more complex than necessary. *[Correct reasoning makes at least one of these points.]*

6. For message authentication, the content of the message does not have to be encrypted.

Solution:True. 1) Message authentication does not provide confidentiality. 2) If anything is encrypted, it's the hash of the message (e.g. a digital signature that encrypts the message digest (hash) with the sender's private key). *[Correct reasoning makes at least one of these points]*

2 Part 2, Optional, for higher grades

1 Hash functions. [A, C, E]

Let x be a message and $x[i]$ be the i-th block of 128 bits of x (e.g., if x is $128 * 3 - 2 = 382$ bit long, $x = x[0] \mid x[1] \mid x[2]$ where the last block is only 126 bits and $\mid$ is block concatenation). Let $pad(x)$ be the padding of x: that is $pad(x) = x$ followed by 0s to fill the last **even** block of x (e.g., if x is $128 * 3 - 2 = 382$ bit long, $pad(x) = x[0] \mid x[1] \mid x[2]]$ followed by 128+2 0s)..
Let $H(x) = AES_d(pad(x)[0], pad(x)[1]) \oplus AES_d(pad(x)[2], pad(x)[3]) \ldots$, where $AES(a, b)$ is encryption of block a using key b and $\oplus$ is bitwise xor.
Remark In AES, both $decrypt(encrypt(m, k), k)$ and $encrypt(decrypt(m, k), k)$ are equal to m.
Assignment (requirements for higher grades are cumulative here)

E A hash function turns input of arbitrary length into output of fixed length (i.e., 128 bits in this case); H is an example of a hash function. To make a hash function **secure**, additional properties are needed. Define these additional properties.

C Is H a secure hash function? For each of the properties that are needed to make a hash function secure, disprove or argue why they hold.

A If H is not secure, describe the consequences of using H as a hash function for an application of your choice. If H is secure, give an example of an application it could be used for.

Solution:
[E] Definitions:

- One-way: it is computationally infeasible to find x such that $H(x) = h$.
- weak collision resistance: it is computationally infeasible to find x' such that $H(x) = H(x')$.
- strong collision resistance: it is computationally infeasible to find x, x' such that $H(x) = H(x')$.

It is not a secure hash function. **[C] Proofs**:

- Not one-way: it is easy to find x such that $H(x) = h$. In fact, we simply set $x = dec(h, 0) \mid 0$, where 0 is a block of 0s.
- No weak collision resistance: it is easy to find x' such that $H(x) = H(x')$. First of all, given x, let $y = pad(x)$ any odd repetions of y (e.g. $y \mid y \mid y$ and $y \mid y \mid y \mid y \mid y$) produce the same hash value as x. Also, for any message x longer than 2 blocks, we can choose an arbitraty block y and set the collision as $x' = dec(H(x), y) \mid y$, and get $H(x') = H(x)$.
- No strong collision resistance: since it is not weak collision resistant

[A] Application: If we use this to hash a password file, since it is not one-way, and the file is leaked we can find a password that produces the desired hash.
Grading

E if the student defines formally and correctly weak collision resistance/one-way/strong collision resistance

C if the student disproves both weak collision resistance and one-way

A if the student provides a valid example.

2 One scenario, several facets [A, C, E] (Grade = highest common level across the facets)

The Never-Ending Notes Company is a startup providing a single service called the Never-Ending Notes (NEN). The idea of NEN is that the service keeps all of your notes and synchronizes them across all your devices. So if you take notes on your laptop running Linux, those same notes will later be available on your iPhone.
NEN Company realized, however, that none of their employees are skilled in cybersecurity. They are aiming high with their product, so they naturally didn't want to settle for anything less than to hire the best of the best to do the security of the NEN product. They hired you, don't let them down!
You received the following brief about the product design:

> NEN Key Ideas
>
> - It must be super easy to set up device syncing.
> - Data is stored in the cloud. This way we can have a subscription-based service.
> - We must support computers, smartphones, tablets.
> - Computers: we have a syncing service running in the background, so that users can write in their normal text editors.
> - Smartphones and tablets: we have an app that does both text editing and syncing.

2a Authentication and access control

The NEN Company gives you the following design proposal that they want you to evaluate for them.

Threat: A NEN Company employee might try to access users' notes to find some sensitive data. For instance, a therapist might use the note taking service to track notes about their patients.

Mitigation: We have three proposed solutions to deal with the threat.

1. We encrypt each users data. The key is derived from the user's password. This way, the insider must know the password or be able to guess it to gain access.
2. We let each client have a randomly generated encryption/decryption key (not based on the password). The clients encrypt the data before sending it to the NEN servers. No one can access the data without that cryptographic key.

   When adding new devices, they must sync the key from an already existing device.

   We can't recover any data if that key is lost. Backing it up securely is our only option.
3. We use several forms of separation of duties. One separation of duties: all user data is encrypted when in storage, it is decrypted by another system for the user before being sent to the user. Another separation of duties: all access to the storage and decryption systems are logged, logs are stored in other systems managed by different people. This means that the attacker must collude with several other people to get access to decrypted user data.

Assignment: Compare the different suggestions, analyse each and suggest which to pick and if you would recommend any amendment to the solution.

Solution: We want to ensure that only the owner of the data can access it. We also want usability for the users.

If we let the users' devices encrypt data before sending it to NEN servers and decrypt it after receiving it, we achieve end-to-end encryption (where the user's devices are the end devices). This means that only the owner of the data can access it.

The downside of this solution is recovery. We cannot recover from lost cryptographic keys. But if we have several devices we have redundancy for the key: the user is unlikely to loose or crash all devices at the same time. If the devices can sync key with each other, we can recover from another device. This can be acceptable.

An alternative solution is that NEN Company technically can access the notes, but no single insider attacker can access the data on their own. Meaning the user must trust NEN Company as a whole, but no individual employee. If we introduce separation of duties, we can achieve this. This allows us to recover any cryptographic keys if we store them on some NEN server. This would also allow us to use BankID for authentication, which is highly usable. This is usable because we don't do passwords and use a very strong authentication mechanism that is already well established. We achieve high security (although lower than end-to-end), but also high usability. In this case the user can loose all their devices, for instance if their work place was burgled or their apartment burned down.

The latter case is more balanced: slightly lower security, but higher usability; as compared to best possible security with decent usability. Normal people (non-nerds, like a therapist) will probably benefit more from the more balanced alternative.

How to grade?

A Solution 3 or any amended solution. The analysis must recognize the trade-off between usability and security.

C The most secure option; the crucial point is that there is no trade-off favouring usability.

E Any factually incorrect statements in the reasoning yields an E.

2b Intrusion detection and prevention

The NEN Company gives you the following design proposal that they want you to evaluate for them.

Threat: A hacker might try to access the system's administrative user interface from the Internet.

Mitigation: We have these proposed solutions to deal with the threat.

1. We set up the firewall to block any connections to the administrative user interface from outside our network. This way, that interface will be completely unreachable from the Internet. We can still use a VPN to access it when working remotely.
2. We have people working remotely, so we can't deny all access to the administrative interface from outside. We allow certain source addresses to access the interface through whitelisting.
3. We allow any connection to the administrative interface from the outside, but we set up an intrusion detection system to monitor for possible attacks and blocks anything that comes up.

Assignment: Compare the different suggestions, analyse each and suggest which to pick and if you would recommend any amendment to the solution.

Solution: The first option (blocking all access) is the best.

The last option (using an IDS) is the worst. This system will likely detect an attack when it's too late. Otherwise it might give too many false positives. We can use prevention sucessfully, so no need to limit ourselves to detection only. (Still an IDS is a good complement.) And whitelisting is a blunt tool: must whitelist a range, not just one IP-address; otherwise it's impossible to maintain with constantly changing IP-addresses.

The second option is a viable trade-off. However, we can actually block all access and use a VPN to workaround the problem. The attacker can never compromise the VPN.

How to grade?

A Solution 1. The crucial point is the superior level of security and maintainability: the analysis must recognize that an attacker must defeat the VPN and that it's easier to maintain than solution 2.

C If they miss any of the parts above in the analysis.

E Any factually incorrect statements in the reasoning yields an E.

2c Denial of Service

Threat: The server running the NEN service could be targeted by an ICMP flood attack. **Mitigation**: NEN have no proposals and ask you. **Assignment**: Which countermeasure can be used to prevent or mitigate this attack and who is in charge of it?

Solution: The most obvious solution is to use ingress filtering close to the attacker, in order to prevent the attacker from spoofing IP and enabling the congested routers to identify and drop malicious traffic. In this case neither NEN or the cloud provider can implement this countermeasure, since they are probably not the network service providers. In this case, the ISP of the attacker is in charge of deploying the countermeasure.

Alternatively, NEN could design the server application to be able to run on multiple servers and the cloud service provider could deploy the application to machines that are connected via different gateways. This would make difficult for an attacker to cause congestions on the links of several routers, spacially if the cloud provides control machines in several greogtaphic areas.

how to grade Problem is P/F. Student passes if they briefly describe at least one effective countermeasure and motivate who is responsible for implementing/deploying it.